Network Security (Computer Security)

Addresses three requirements:

- ***Confidentiality.*** Prevent unauthorized users from accessing or utilizing resources
- ***Availability***. Ensure that resources are ***available*** when users need access to them
- ***Integrity.*** Verify the ***integrity*** of the resources (make sure things have not been corrupted or maliciously altered)

Security Aspects

Three aspects of security:

- ***Vulnerability*** - identify the parts of a network or system that can cause problems in terms of overall security
- ***Threats*** - persons, entities, organizations, or events that can exploit a vulnerability and cause a system to fail
- ***Countermeasures*** - steps or actions taken by system administrators to reduce vulnerabilities or to prevent security threats from becoming realized

Attacks

- "Attacks" are specific instances of a threat being realized, i.e., when somebody attempts to break into a system or circumvent security policies, this is called an "attack"

Network Security Threats

- Two categories of threats
- ***Passive threats*** such as eavesdropping, monitoring of transmissions, etc.
- ***Active threats*** involve some modification of transmitted data or creation of false transmissions

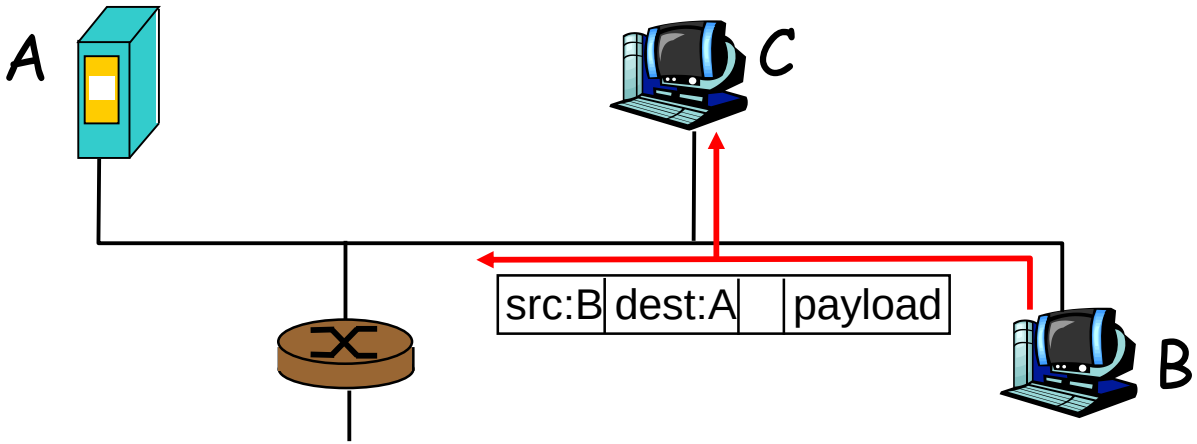
Passive Attacks

- Involve no modification of data stream
- Eavesdropping or monitoring of transmissions
- Two types:
  - Release of message contents
    - getting access to confidential or sensitive information in an e-mail message or in a transferred file
  - Traffic analysis
    - Very subtle
    - Attacker captures messages to analyze the nature of different ongoing transmissions
- Very difficult to detect

An Example of Passive Attack

Packet sniffing:

- broadcast media
- promiscuous NIC reads all packets passing by
- can read all unencrypted data (e.g. passwords)
- e.g.: C sniffs B's packets



Active Attacks

- Involve some modification of data stream or creation of false stream
- Can be divided into four categories
  - **Masquerade**
    - When one pretends to be a different entity i.e impersonating an entity that has extra privileges
  - **Replay**
    - Involves passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect

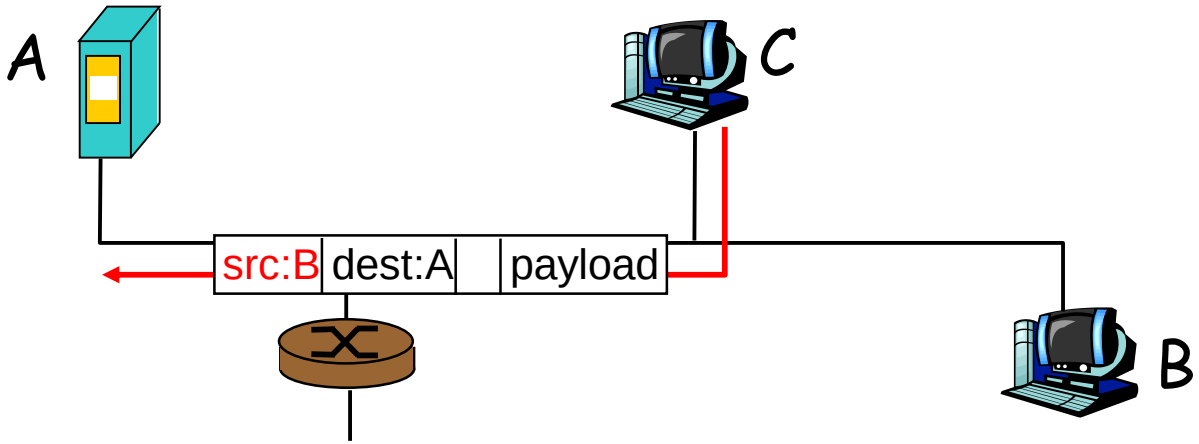
Active Attacks (Cont'd)

- **Modification of messages**
  - Some potion of a legitimate message is altered
  - Messages are delayed or reordered to produce an unauthorized effect
- **Denial of service attack**
  - Prevents or inhibits the normal use or management of communication facilities
  - Examples:
    - Attacker may suppress all messages directed to a particular destination
    - Disabling a network or overloading a network with messages

Example 1: Active Attack

IP Spoofing:

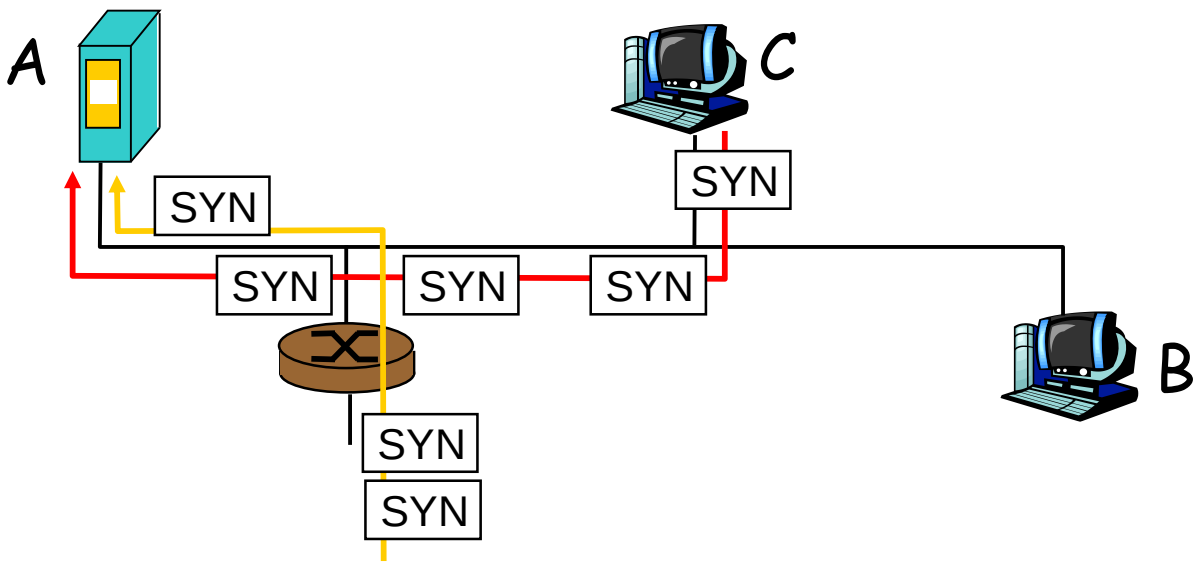
- can generate "raw" IP packets directly from application, putting any value into IP source address field
- receiver can't tell if source is spoofed
- e.g.: C pretends to be B



Internet security threats

Denial of service (DOS):

- flood of maliciously generated packets "swamp" receiver
- Distributed DOS (DDOS): multiple coordinated sources swamp receiver
- e.g., C and remote host SYN-attack A



Passive versus Active Attacks

- Passive attacks are difficult to detect
- Active attacks are easy to detect
- Passive attacks are easy to prevent such as by using encryption techniques
- Active attacks are difficult to prevent as the process would require physical protection of all network facilities and paths all times

Absolute Security?

- No computer or network system can ever be considered absolutely secure
- The more secure a system needs to be, the more it costs to implement additional security measures

Important Note about Computer Security

- ***Computer security*** has become an activity of *identifying* threats and vulnerabilities in a system, *estimating* the risk of threats being realized, *determining* the value of the resources that are at risk, and *comparing* the benefits to be achieved by securing a resource against the cost of implementing that security

Examples of vulnerabilities

- ***Physical vulnerabilities***
  - Example: parts of a computer may be physically damaged by a number of different threats
- ***Natural vulnerabilities***
  - Example: Computers can be affected by natural events (flood, fire, heat, humidity, dust, etc.)
- ***Hardware/software vulnerabilities***
  - Example: Computer components fail to work properly (wear out, incorrect design, implementation problems, conflicts with other systems)

Examples of vulnerabilities (continued)

- ***Media vulnerabilities***
  - Examples: disks and tapes wear out, erasure vulnerabilities, other physical characteristics of media that can fail, magnetism
- ***Emanation vulnerabilities***
  - Example: Computers and computer systems "leak" information in ways we don't want them to (radio frequency leakage from network wiring, video monitors)
- ***Communications vulnerabilities***
  - Communications can be intercepted or faked.

Examples of vulnerabilities (continued)

- ***Human vulnerabilities***
  - Vulnerabilities related to the fact that computers are typically used by people; people give out information they shouldn't, people often forget things, delete files or enter in incorrect commands, improper usage of a system, bribery/sabotage

Example Sources of Threats

- ***Natural and Physical Threats***
  - Threats that are inherent from being physical devices and subject to disasters (e.g., earthquakes, fires, floods, lightning, hurricane, power spikes,etc.)
- ***Unintentional Threats***
  - Dangers due to ignorance or accident (dropping a disk drive, spilling a drink into a computer, using equipment improperly, entering the wrong command)

Example Sources of Threats (Cont'd)

- ***Intentional Threats***
  - ***Outsiders vs. Insiders***
  - ***Outsiders threats***
    - From outside an organization
    - Foreign Intelligence Agents (spies), terrorists, criminals, corporate Raiders, crackers
  - ***Insiders threats***
    - From inside an organization
    - Fired or upset employees (or students), coerced employees (blackmail, bribery, threats to employment), lazy or untrained users
- One of the *most effective attacks* on a system is to combine an outsider threat with an insider threat

Examples of Countermeasures

- Backups
- User Training
- Uninterruptible Power Supplies (UPS)
- Mirrors
- Security/System Administration Tools
- Enforcement of good password schemes
- Alternate Authentication Mechanisms
- **Encryption**
- Audit Trails / System Logs
- Inquisitive Users/Administrators
- Locks/Physical Security
- Network Analyzers/Reporting Tools
- Secure Hubs/Equipment with security features
- Virus Detection/Eradication systems
- Firewalls

Passwords, encryption, and authentication

- Mechanisms of determining identity of requestor and degree of access
  - **Identification** - mechanism used so that a user requesting a service can identify himself/herself to the system. The most common identification mechanism is a username, although others can exist.
  - **Authentication** - mechanism used to verify the identity of a person. The most common authentication mechanism is the use of a password.
  - **Authorization** - mechanisms used to determine what actions a user is allowed to perform on a system. The most common authorization mechanisms are permission controls and/or access control lists.

Authentication

- Can be broken down into three broad categories
  - **Something a user knows** - examples: passwords, birthdates, mother's maiden name, PIN numbers, SSNs, birthplace pet names, etc
  - **Something a user has** - examples: keys, tokens, credit cards, identification cards
  - **Something the user is** -- a physical characteristic unique to the person being authenticated. examples: fingerprints, retina scans, DNA scans, voice print analysis

Password authorization schemes

- Encryption schemes
  - An "encryption scheme" is some method that is used to encode information such that the original contents of the information are not easily seen or determined by unauthorized persons
- Two broad classes of encryption schemes
  - Two-way encryption schemes
    - allows information to be encrypted (encoded) into a format that can be transmitted and then later decrypted (decoded) into its original format
  - One-way encryption schemes

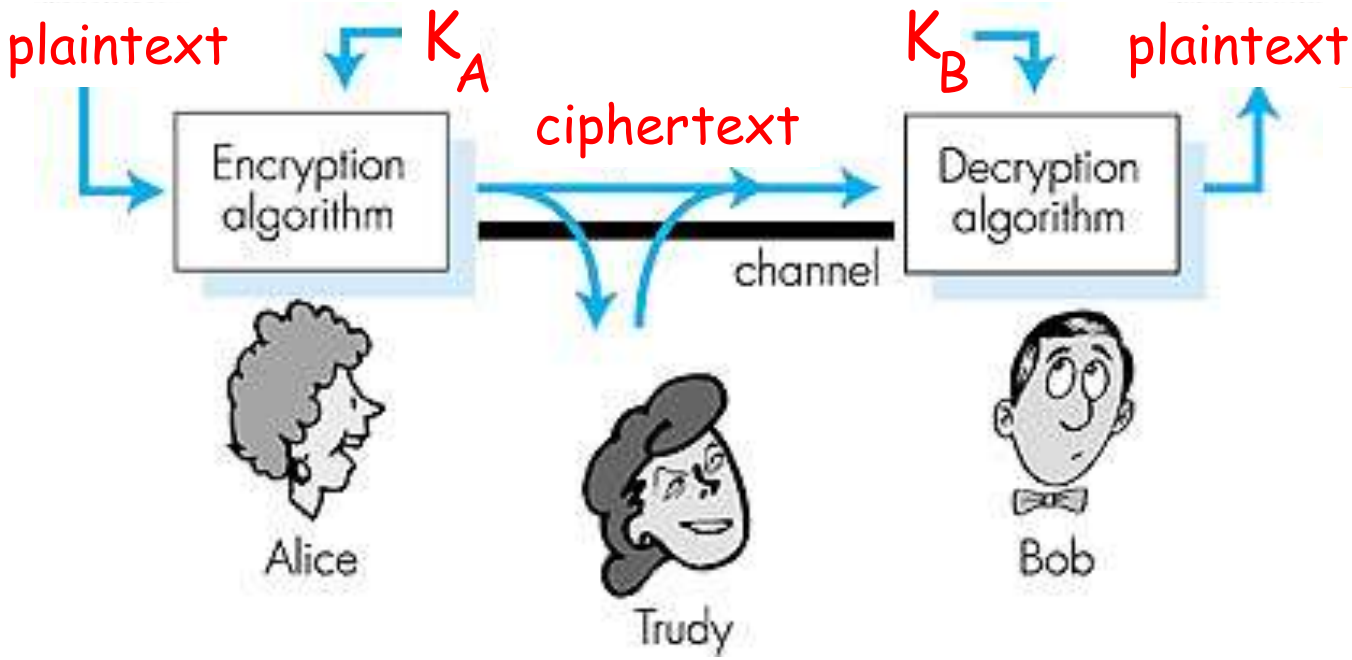
Terms used for encryption schemes

- **Cleartext**
  - Information in its original, unencrypted form
- **Ciphertext**
  - Information after it has been encrypted
- **Key**
  - Something used in the encryption and decryption process to convert cleartext to ciphertext and vice-versa
- *Note: A good encryption algorithm is one in which it is nearly impossible to deduce the cleartext form of information from the ciphertext without having the appropriate key*

Normal Process for Two-Way Encryption

- cleartext --encrypt(key)--> ciphertext --transmit-to-receiver-->
- ciphertext --decrypt(key)--> cleartext

The language of cryptography



symmetric key cryptography:

sender, receiver keys identical and *secret*

public-key cryptography:

encrypt key *public*, decrypt key *secret*

How good is an Encryption Scheme?

- Difficulty of "breaking a code or encrypted message" depends on the size of the key
- In general, a longer key value will make a particular encryption more secure
- For most encryption methods, the only way a cracker can break the encryption is to try every possible key (this is known as a "brute-force attack")
- The greater the number of possible keys, the less likely a brute-force attack will succeed

Encryption Key

- Most keys are measured in terms of the number of bits
  - A 16-bit key means that there are 65K possible keys (2^{16}=65536)
  - A 32-bit key means that there are 4 billion possible keys
  - A 64-bit key means that there are 16 quadrillion possible keys
- A system that can test 1000 key values per second would take
  - 65 seconds to test a 16-bit key
  - 49 days to test a 32-bit key
  - Thousands of years to test a 64-bit key

One-way Encryption Scheme

- A cleartext string is converted into a ciphertext form
- Cannot be converted back to the cleartext form
- Often used for authenticating passwords

Example: One-way Encryption Scheme

- A user enters a password into a system to set his/her password
- The system then encrypts the password using a one-way encryption scheme, and stores the ciphertext version of the password in a database
- Then, when the user wishes to authenticate himself/herself to the system, he/she supplies the same password to the system
- The system encrypts the user-supplied authentication password, which should match the encrypted-form stored in the system's password database

One-way Encrytion Schemes (Cont'd)

- Irreversible encryption schemes like some mathematical operations (Ex. modulus operation)
- Difficult to break to determine the original password

Password attacks

- One-way encryption scheme is effective but can fail
- Many users will not choose good passwords
- *Crack programs*
  - *Do not need to attempt **all** combination of passwords*
  - *Can use common words in an attempt to find a poorly chosen password*
- Most crackers look for any password to gain access to a system
- Rarely some crackers look for a password for administrative access

Countermeasures for preventing password attacks

- Train and/or require users to use good passwords
  - A good password is not a word, a name, a birthdate or a social security number. Why?
  - Best passwords are random sequences of characters and non-letter with mixed case
  - Example: Using initial letters of an easy-to-remember phrase. A password "ttl*hiwwya" is derived from phrase "twinkle twinkle little star, how I wonder what you are"
- Configure systems to refuse to allow users to set a bad password

Countermeasures for preventing password attacks

- Secure the password databases so that the encrypted forms are not available to users (on UNIX systems, this known as "shadow passwords" since the actual passwords are kept in a "shadow" file which is not accessible to average users)

- Don't use passwords as the primary authentication mechanism (there are others)

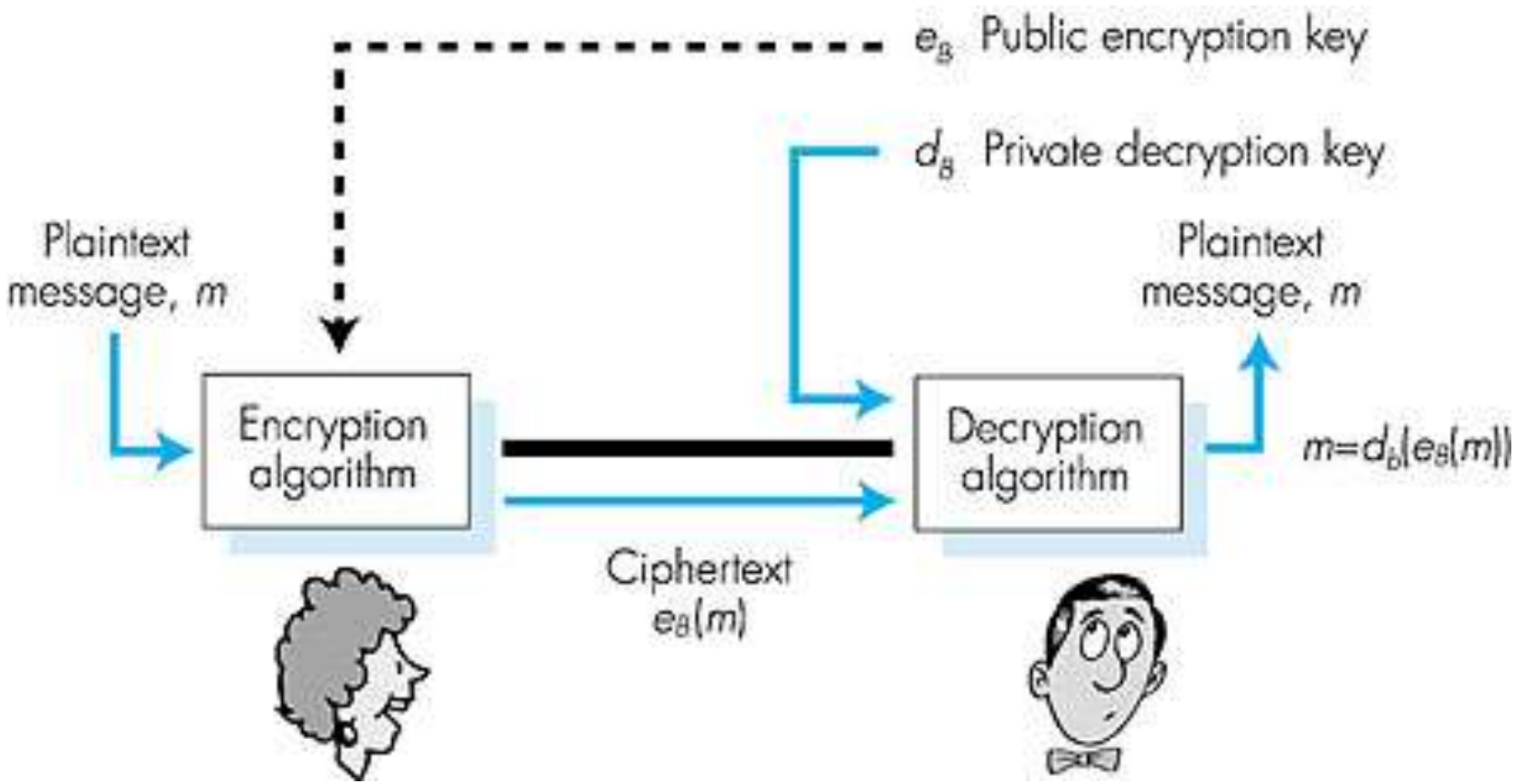
Problem with Symmetric Key Cryptography

- Requires sender, receiver know shared secret key
- Questions:
  - How to agree on key in first place (particularly if never "met")?
  - How to tell about the key to other party over Internet, a publicly accessible medium?

Public Key system encryption methods

- Two-way encryption system
- A complex mathematical algorithm generates keys with two halves
- Whatever is encrypted by one half of the key can only be decrypted by the other half
- Has the capability of allowing messages to be sent securely without having to keep a key secret from the rest of the world
- Two halves of the key are known as the ***public key*** and ***private key*** depending on who receives the keys

Public Key Cryptography



Public Key System Encryption Methods(Cont'd)

- A person wanting to receive secure messages
  - Will generate a public/private key pair
  - Supply the public key to anyone who wants to send them a secure message
  - The receiver keeps the private key secret
- When a sender wants to send a secure message to a receiver
  - Sender encrypts the message using receiver's public key
  - Encrypted message is sent to receiver
  - Receiver decrypts the message using his/her private key
- Message delivery is secured
  - No one but the receiver knows the private key corresponding to the public key

Authentication Mechanism: Digital Signatures

- Digital signature
  - Mechanism for verifying the authenticity of the sender of a message
- Can use public key cryptography to implement
  - Sender encrypts the message using his/her private key
  - Recipients decrypt the message using the sender's public key
  - The message is authentic if readable after decryption
- Can be used to validate that a document has not been altered in transit if the encrypted form is altered in any way, then it will not decrypt with the sender's public key

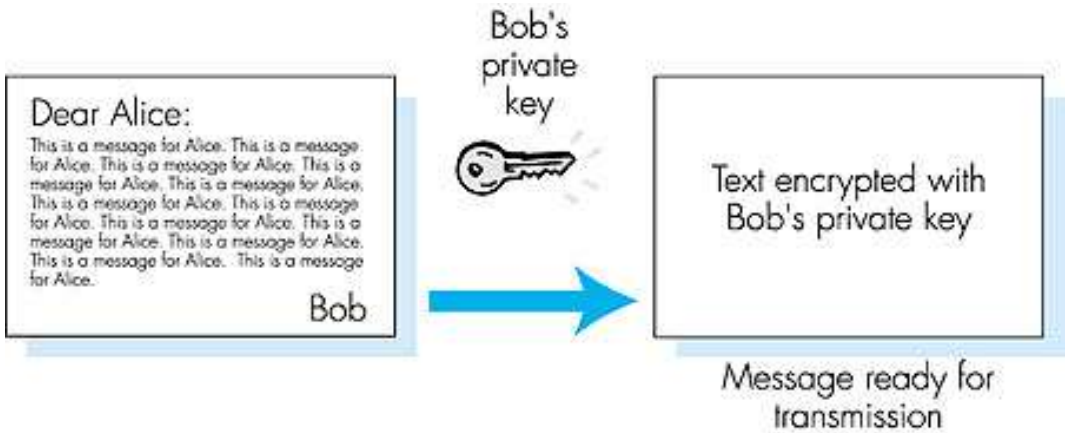
Digital Signatures

Cryptographic technique analogous to hand-written signatures.

- Sender (Bob) digitally signs document, establishing he is document owner/creator.
- Verifiable, nonforgeable: recipient (Alice) can verify that Bob, and no one else, signed document.

Simple digital signature for message m:

- Bob encrypts m with his public key d_B, creating signed message, $d_B(m)$.
- Bob sends m and $d_B(m)$ to Alice.



Pretty Good Privacy (PGP) Protocol

- Popular protocol
- Used for sending/receiving encrypted and digitally signed electronic mail over the internet
- Is known as PGP (*Pretty Good Privacy*)
- Used for interactive Internet communications
- Usually known as "Secure Sockets Layer" (SSL)
- With SSL, every packet sent over the network is encrypted
- A new protocol is being developed for use on the Internet that is known as IPsec (*Internet Protocol w/security*)

Side Note

There are U.S. export restrictions on the export of any form of cryptography (other than those approved by the NSA) outside of the United States/Canada. This includes technologies such as PGP and public key cryptography

Programmed Threats

- **Programmed Threat**
  - An item of software or hardware that is intended to (or has the result of) compromising system security
- **Categories of programmed threats**
  - **Security tools and toolkits** -- programs designed to assist with securing a system by exposing vulnerabilities
  - **Back doors** -- secret codes or routines that allow unauthorized access to a system
  - **Logic bombs** -- a program that is set to do something specific (often destructive) whenever a pre-programmed event occurs. Example events: dates, a certain combination of keystrokes, etc.

Programmed Threats (Cont'd)

- **Categories of programmed threats** (Cont'd):
  - **Viruses** -- program that attaches itself to other programs and is executed whenever the host program is executed (so it can copy itself to other programs)
  - **Worms --** programs that are designed to attack as many computers as possible through a network (a worm is usually a standalone program)
  - **Trojan Horses** -- program that appears to have one function but actually has another hidden purpose
  - **Bacteria or Rabbit attacks** -- programs that rapidly multiply in order to bring down a system

Programmed Threats (cont'd)

- **Bacteria and rabbit programs** exhibit a special type of attack that is known as a "Denial of Service" (DoS) attack, preventing other (legitimate) users from being able to use the system effectively
- One form of denial of service attack is to flood a machine or network with **ping requests**
- **Email spam** often has the effect of being a denial of service attack

Side Note

- *In the past few years, some organizations (e.g., the Pentagon) have been experimenting with* ***reverse denial-of-service attacks****. When a computer detects that someone is attempting to breach its security, it retaliates by* ***flooding the attacking computer with denial-of-service attacks****. (Note that this is illegal.)*

Firewalls

- Firewall
  - A general name for hardware, software, or combination of the two
  - Used to protect internal network from intruders
  - Works as a transit device that examines traffic and decides what traffic (packet) should pass or should not pass

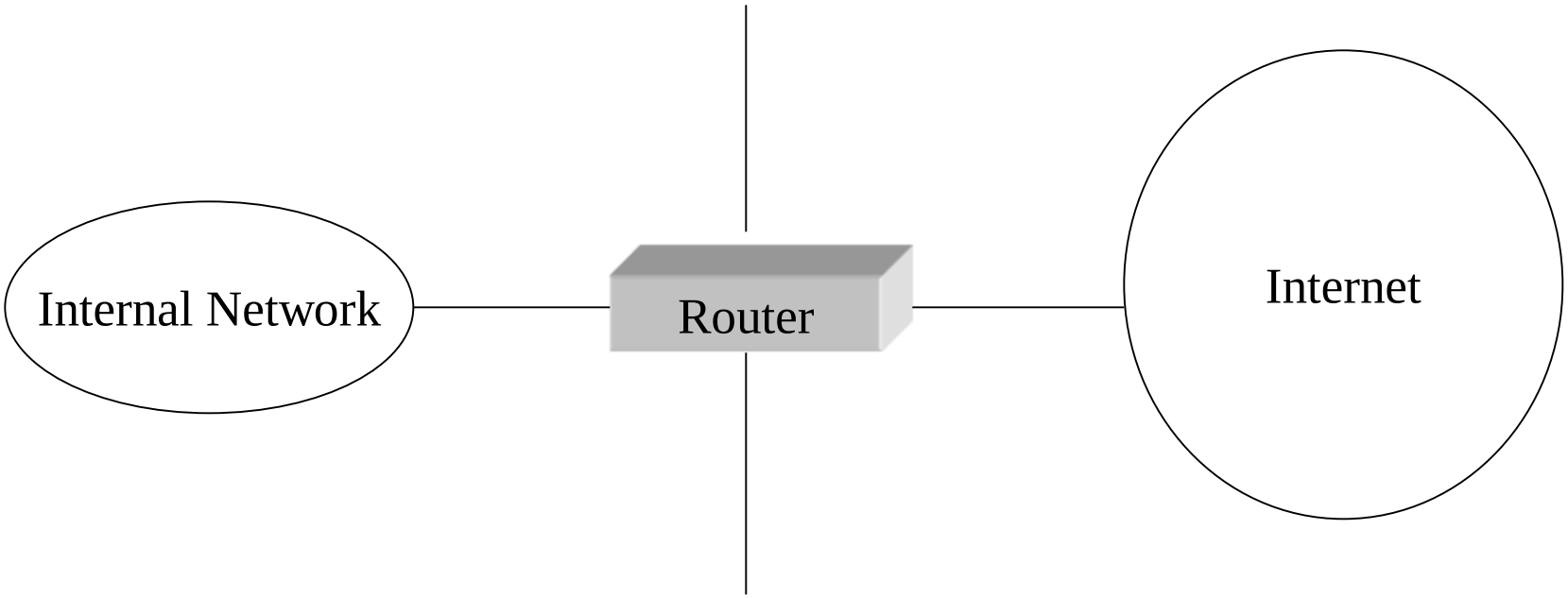
Typical Firewall Components

- Hardware
  - Routers
  - Dedicated computers
  - Special hardware device such as Cisco PIX (Private Internet eXchange)
- Software
  - Firewall software

Role of Routers

- Operate at the network level
- Understand source and destination IP addresses
- Understand packet types
- Can be configured to
  - allow only certain type of packets to pass
  - allow connections to be established only from a certain set of internal hosts
  - block any attempts to access internal hosts from the external, unsafe Internet
- Process is called *packet filtering*

A Simple Firewall System with a Router



Limitations of Routers

- Routers understand only the information in the TCP/IP headers
- Routers do not understand data in the application protocol level (such as HTTP)
- Routers cannot enforce authentication of users
- Routers access control capabilities are limited to IP address level
- Routers are not able to provide meaningful logs of transactions that occur

Application-Level Firewalls

- Perform more complex tasks than the capabilities of router hardware
- Understand the application
- Understand the application content
- Can perform intelligent tasks such as filtering mail based on its source and contents

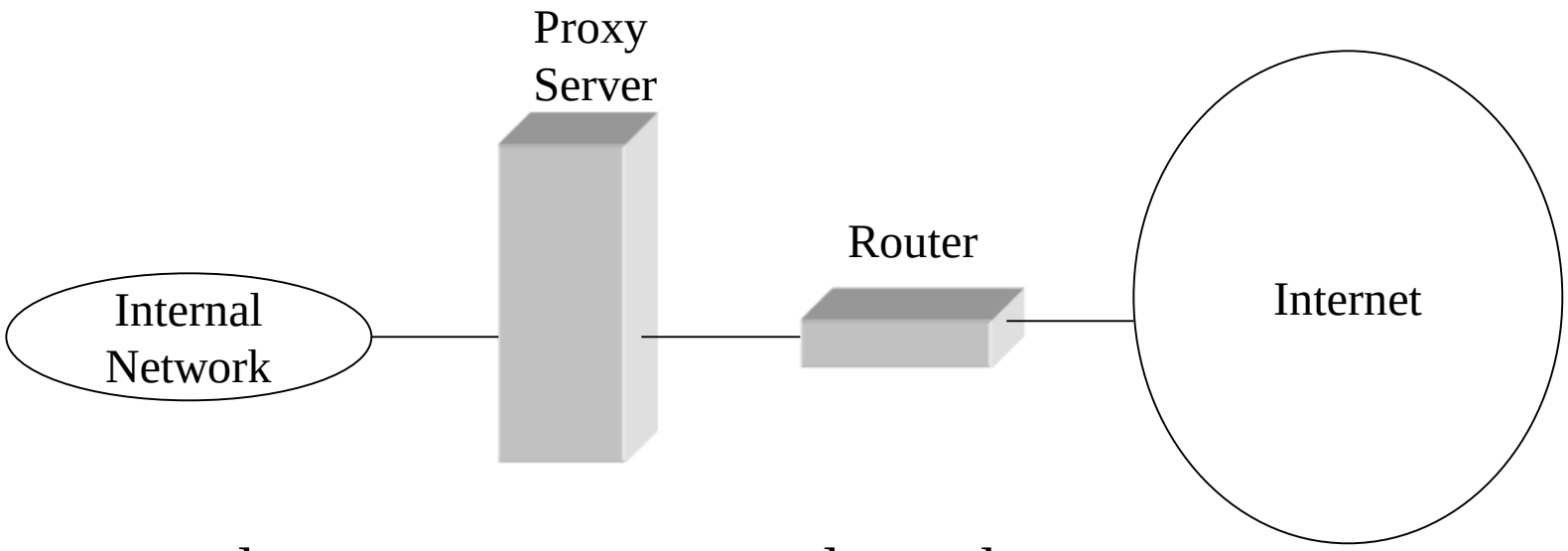
Application-Level Proxy Servers

- Software programs that are familiar with a specific or several protocols
- Application-level gateways
- Clients on internal networks make requests to the proxy server instead of connecting directly to a remote device
- Proxy server performs the actual request on behalf of the client
- Relay authorized traffic between interfaces
- Block unauthorized traffic

Important Features of Application-Level Proxy Servers

- Latency Reduction, Bandwidth Conservation
  - Cache data and service requests from their cache
- Advanced Access Control
  - Can perform authentication and use authentication information in access control
- Advanced Filtering
  - Understand the internals of the protocol
  - Filter out sensitive information
  - Insert additional information
  - Remap request to a mirror site
- Logging and auditing
  - Able to provide extensive logs of transactions
  - Can be used for auditing of Web traffic

A Firewall with a Proxy Server and a Router

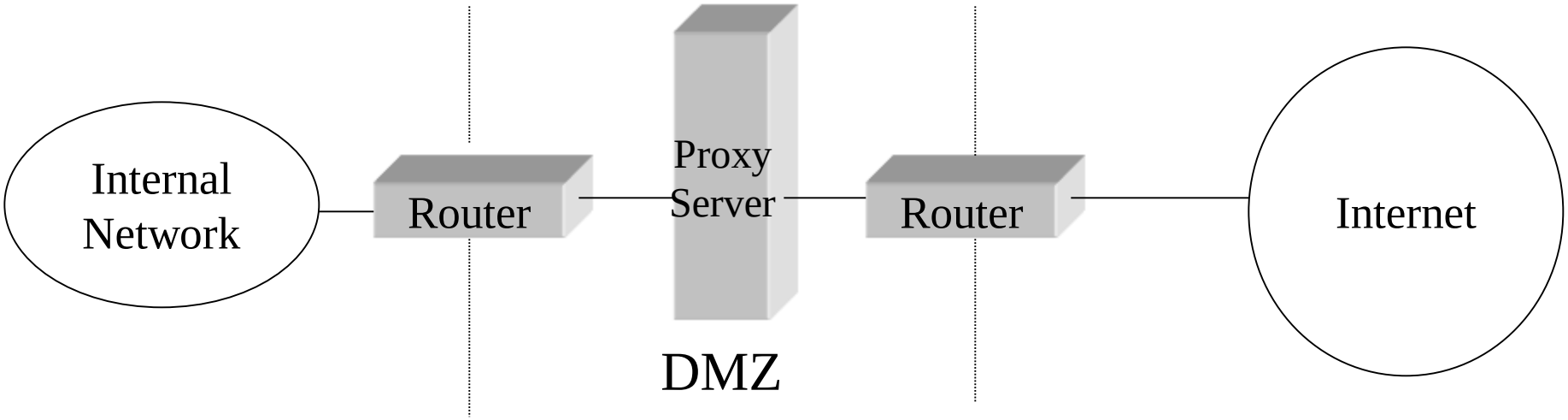


- Routers and proxy servers are used together
- Provide a more secure solution
- Router protects the proxy server from Internet

Problem

- We want to prevent people from accessing internal networks
- Also we want to provide services to outside world
- Services must be visible to external networks
- How is it possible?
- Solution:
  - Create what is commonly known as a "DMZ" (Demilitarized Zone), a third network attached to firewall. DMZ is a subnet.
  - Place servers and other computers that need to be visible to users outside of the organization's on DMZ
  - These services are vulnerable. Hence place a second firewall that protects the internal LAN from the computers in DMZ

A Firewall with a Proxy Server Enclosed in a Subnet Protected by Two Routers



- Proxy server is surrounded by a router on both sides
- More secured
- Proxy server is on its own subnet
- Subnet is referred to as demilitarized zone (DMZ)

Demilitarized Zone (DMZ)

- Part of network which lies between Internet and internal network (intranet)
- Shields rest of intranet from threats of Internet
- More exposed to threats of Internet than internal hosts
- More stringent security measure must be taken on this zone